CONFIDENCIAL

INFORME DE TEST DE INTRUSIÓN

Evaluación de seguridad y escalada de privilegios

Objetivo: 172.17.0.2 · Servicio SSH (OpenSSH 8.9p1)

Vector: binario SUID abusable (GTFOBins — find)

Autor	**Josep Sanz**
Rol	Analista de Seguridad Ofensiva (Pentester)
Fecha del informe	4 de noviembre de 2026
Tipo de prueba	Caja gris · Infraestructura interna
Clasificación	CONFIDENCIAL
Versión	1.0

Índice

1. Resumen ejecutivo

El presente documento recoge los resultados de un test de intrusión realizado sobre el sistema con dirección IP 172.17.0.2. El objetivo del ejercicio consistió en evaluar la postura de seguridad del equipo, identificar vulnerabilidades explotables y demostrar, mediante una prueba de concepto controlada, el impacto real que un atacante con acceso de usuario sin privilegios podría llegar a conseguir.

Partiendo de un acceso de usuario estándar (cuenta «hacker»), se consiguió escalar privilegios hasta obtener control total del sistema como usuario «root». El vector de ataque se basó en el abuso de un binario con el bit SUID activado (/usr/bin/find), una técnica de explotación bien documentada que permite ejecutar una shell con los privilegios del propietario del binario. Como evidencia de la obtención de máximos privilegios se recuperó el fichero /root/flag.txt, accesible únicamente por el usuario root.

Valoración global del riesgo

Nivel de riesgo	Vulnerabilidades	Acceso obtenido	Objetivo
ALTO	1 explotada (SUID)	root (euid=0)	Comprometido

La facilidad de explotación (no requiere exploits complejos ni condiciones poco frecuentes) y el impacto máximo (compromiso total del equipo) hacen que el hallazgo se clasifique con una severidad ALTA, con prioridad de remediación elevada.

2. Alcance y objetivos

2.1. Alcance

El alcance de la evaluación se limitó estrictamente al siguiente activo, dentro de un entorno controlado de laboratorio:

Dirección IP objetivo	172.17.0.2
Sistema operativo	Linux (Ubuntu)
Servicio expuesto	SSH — OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (puerto 22/tcp)
Dirección MAC	42:E9:2C:B7:ED:6F
Tipo de prueba	Caja gris (se dispuso de credenciales de usuario sin privilegios)

2.2. Objetivos

- Identificar los servicios y la superficie de ataque expuesta por el sistema objetivo.
- Enumerar posibles vías de escalada de privilegios desde una cuenta de usuario estándar.
- Demostrar de forma controlada la explotación de las debilidades encontradas.
- Obtener la máxima prueba de impacto (acceso como root y lectura del fichero de evidencia).
- Proporcionar recomendaciones de remediación claras y accionables.

© 2026 — Uso restringido

2.3. Advertencia legal

Las actividades descritas en este informe se realizaron en un entorno de laboratorio controlado y con la debida autorización. La información aquí contenida es estrictamente confidencial y debe tratarse como tal. La reproducción de las técnicas descritas sobre sistemas sin autorización expresa y por escrito constituye un delito.

3. Metodología

La evaluación siguió un enfoque estructurado, alineado con metodologías reconocidas del sector como PTES (Penetration Testing Execution Standard) y OWASP, adaptado a un ejercicio de escalada de privilegios local. Las fases ejecutadas fueron:

- **Reconocimiento y enumeración de red:** descubrimiento de puertos y servicios mediante Nmap.
- **Enumeración local:** búsqueda de binarios con bit SUID como posibles vectores de escalada.
- **Explotación:** abuso del binario SUID identificado para obtener una shell privilegiada.
- **Post-explotación:** confirmación de privilegios y obtención de la evidencia (flag).

Herramientas utilizadas

Herramienta	Uso en el ejercicio
Nmap 7.991	Escaneo de puertos, detección de versiones y scripts por defecto.
find	Enumeración de binarios SUID y vector de explotación (GTFOBins).
Shell / SSH	Acceso interactivo al sistema objetivo.
GTFOBins	Base de conocimiento de referencia para el abuso del binario find.

4. Desarrollo técnico de la intrusión

4.1. Fase 1 — Reconocimiento con Nmap

Se inició la evaluación con un escaneo exhaustivo del objetivo mediante Nmap, cubriendo la totalidad de los 65.535 puertos TCP. Se emplearon las opciones de detección de versión de servicio (-sV), scripts por defecto (-sC), escaneo SYN (-sS) y una tasa de paquetes elevada (--min-rate=5000) para agilizar el proceso. El comando ejecutado fue el siguiente:

```
$ nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
```

El resultado del escaneo revela que el sistema mantiene un único puerto accesible, el 22/tcp, correspondiente al servicio SSH. Los 65.534 puertos restantes se encuentran cerrados, lo que indica una superficie de ataque de red muy reducida y bien acotada.

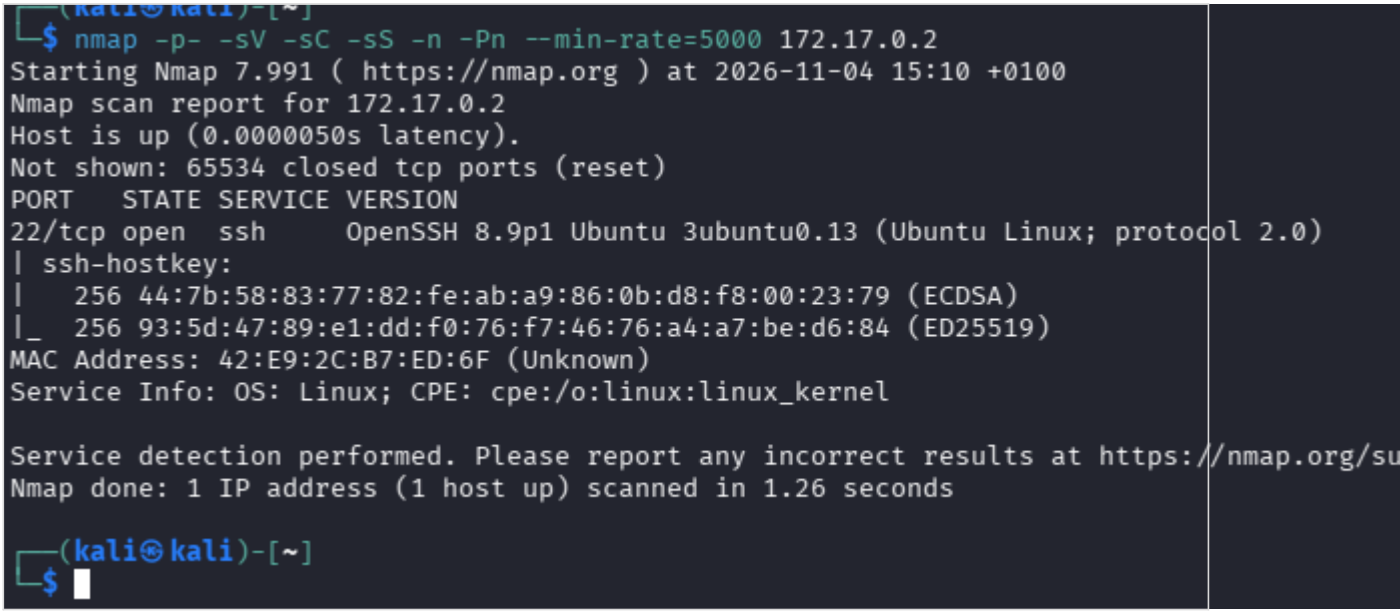


Figura 1. *Escaneo Nmap del objetivo 172.17.0.2. Se observa el único puerto abierto (22/tcp — OpenSSH 8.9p1) y la información del host.*

Hallazgos de la fase de reconocimiento

Puerto	Estado	Servicio / Versión
22/tcp	**Abierto**	ssh — OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (protocol 2.0)
65534	Cerrados	Sin servicios expuestos (reset)

La versión de OpenSSH identificada (8.9p1) se encuentra parcheada y no presenta vulnerabilidades críticas conocidas de ejecución remota en el momento de la evaluación. Por tanto, el acceso al sistema se consideró a través de credenciales válidas de usuario, acorde con la naturaleza de caja gris del ejercicio.

4.2. Fase 2 — Enumeración de binarios SUID

Una vez con acceso al sistema como el usuario «hacker» (sin privilegios), se procedió a la enumeración local en busca de vías de escalada. Una de las técnicas más efectivas consiste en localizar binarios que tengan activado el bit SUID (Set User ID). Estos binarios se ejecutan con los privilegios de su propietario —habitualmente root— en lugar de con los del usuario que los invoca. El comando utilizado fue:

```
hacker@02f94f9cc255:~$ find / -perm -4000 2>/dev/null
```

El modificador -perm -4000 filtra los ficheros con el bit SUID establecido, mientras que la redirección 2>/dev/null descarta los errores de permiso denegado para obtener una salida limpia. El resultado se muestra en la siguiente captura:

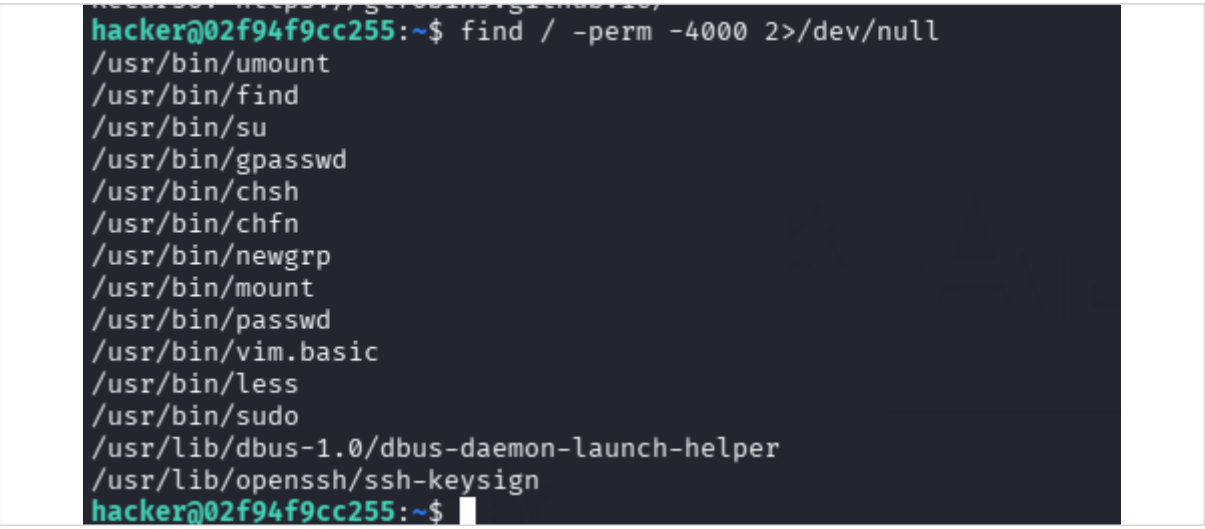


Figura 2. *Listado de binarios con bit SUID activo en el sistema objetivo. Destaca la presencia de /usr/bin/find, abusable para escalar privilegios.*

Entre los binarios listados, la mayoría (passwd, su, sudo, mount, etc.) son estándar del sistema y su bit SUID es legítimo y necesario. Sin embargo, destaca especialmente la presencia de:

Binario	Observación
/usr/bin/find	SUID NO estándar. Listado en GTFOBins como vector de escalada de privilegios. Permite ejecutar comandos arbitrarios con los privilegios del propietario (root).
/usr/bin/vim.basic	También potencialmente abusable, aunque no fue necesario en esta prueba.

La presencia del bit SUID sobre /usr/bin/find constituye una configuración insegura: este binario no requiere privilegios elevados para su funcionamiento normal y su capacidad de ejecutar comandos externos (-exec) lo convierte en una herramienta ideal para la escalada.

4.3. Fase 3 — Explotación y escalada de privilegios

Confirmado que /usr/bin/find dispone del bit SUID, se procedió a su explotación siguiendo la técnica documentada en GTFOBins. El comando aprovecha la opción -exec de find para lanzar una shell (/bin/sh) con el flag -p, que preserva los privilegios efectivos (evitando que la shell descarte el euid de root). El comando ejecutado fue:

```
hacker@02f94f9cc255:~$ /usr/bin/find . -exec /bin/sh -p \; -quit
```

Tras la ejecución, el prompt cambia de «$» a «#», señal inequívoca de que se dispone de una shell con privilegios de root. La verificación mediante el comando id confirma la escalada: el identificador de usuario efectivo es euid=0(root), a pesar de que el identificador real sigue siendo el del usuario «hacker» (uid=1000).

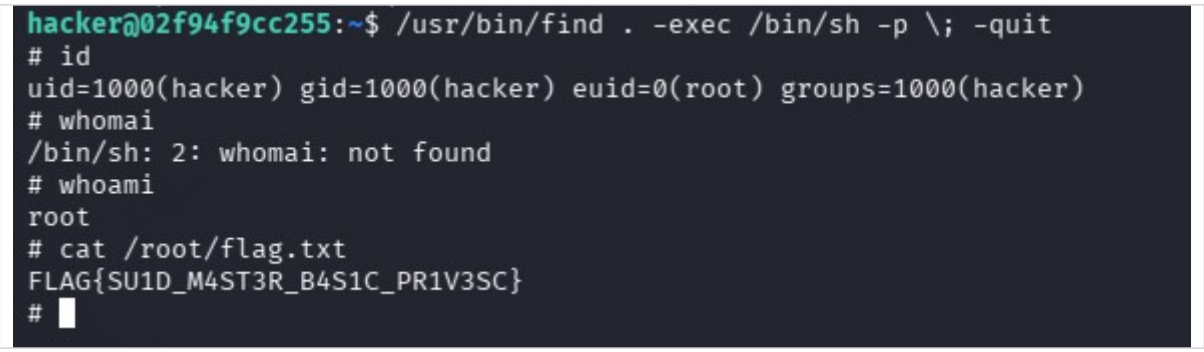


Figura 3. *Escalada de privilegios exitosa. El comando id muestra euid=0(root), whoami devuelve «root» y se obtiene la lectura del fichero protegido /root/flag.txt.*

Análisis de la evidencia

- **`id` →** `uid=1000(hacker) gid=1000(hacker)` **`euid=0(root)`** — privilegios efectivos de root confirmados.
- **`whoami` → `root`** — control total del sistema.
- **`cat /root/flag.txt` →** acceso a un recurso restringido exclusivamente a root.

Evidencia obtenida (flag): `FLAG{SU1D_M4ST3R_B4S1C_PR1V3SC}`

La lectura satisfactoria del fichero /root/flag.txt constituye la prueba de concepto definitiva del compromiso total del sistema.

5. Ficha de la vulnerabilidad

Identificador	**PRIVESC-001**
Título	Escalada de privilegios local mediante binario SUID abusable (/usr/bin/find)
Severidad	**ALTA** (CVSS 3.1 estimado: 7.8 — AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)
Categoría	CWE-250: Ejecución con privilegios innecesarios · CWE-732: Permisos incorrectos sobre recurso crítico
Activo afectado	172.17.0.2 — /usr/bin/find
Vector	Local (requiere acceso previo de usuario)
Complejidad	Baja — técnica pública y de ejecución trivial
Impacto	Compromiso total del sistema (confidencialidad, integridad y disponibilidad)

Descripción

El binario /usr/bin/find tiene asignado el bit SUID con propietario root. Dado que find permite la ejecución de comandos arbitrarios a través de su parámetro -exec, cualquier usuario local puede abusar de esta configuración para lanzar una shell que hereda los privilegios efectivos de root, obteniendo así control total del sistema.

Impacto

Un atacante con acceso de usuario sin privilegios —obtenido, por ejemplo, mediante credenciales filtradas, una cuenta de servicio o la explotación de otra aplicación— puede convertirse en administrador del sistema. Esto le permitiría acceder a información confidencial, modificar o destruir datos, instalar puertas traseras persistentes y utilizar el equipo como pivote hacia el resto de la red.

6. Recomendaciones de remediación

Se proponen las siguientes acciones correctoras, ordenadas por prioridad:

Prioridad alta — Corrección inmediata

- **Eliminar el bit SUID de /usr/bin/find**, ya que no es necesario para su funcionamiento habitual. Ejecutar:

```
# chmod u-s /usr/bin/find
```

- Auditar el resto de binarios SUID del sistema y retirar el bit a todos aquellos que no lo requieran estrictamente (por ejemplo, vim.basic). Mantener únicamente los binarios SUID legítimos e imprescindibles.

Prioridad media — Refuerzo (hardening)

- Aplicar el principio de mínimo privilegio en todo el sistema, revisando permisos de ficheros y pertenencia a grupos.
- Implementar monitorización y alertas sobre cambios en los permisos de binarios críticos (p. ej., mediante AIDE o auditd).
- Montar las particiones que no requieran binarios SUID con la opción nosuid.

- Establecer un proceso periódico de revisión de binarios SUID/SGID como parte de la gestión de la configuración.

Prioridad baja — Buenas prácticas

- Reforzar la gestión de credenciales de usuario para dificultar el acceso inicial no autorizado.
- Mantener el sistema y los paquetes actualizados de forma continua.
- Formar al personal técnico en configuraciones seguras de permisos en sistemas Unix/Linux.

7. Conclusiones

La evaluación ha demostrado que, pese a presentar una superficie de ataque de red muy reducida (un único servicio SSH correctamente parcheado), el sistema 172.17.0.2 es vulnerable a una escalada de privilegios local trivial. Una configuración insegura de permisos —el bit SUID sobre el binario /usr/bin/find— permitió pasar de un usuario sin privilegios a control total como root en un único paso.

Este hallazgo subraya la importancia de no limitar las evaluaciones de seguridad al perímetro de red, sino de auditar también la configuración interna de los sistemas. La remediación propuesta es sencilla y de bajo coste, pero su impacto en la reducción del riesgo es muy elevado. Se recomienda aplicar las medidas correctoras de prioridad alta de forma inmediata y planificar una reevaluación una vez implementadas.

Elaborado por:

Josep Sanz
Analista de Seguridad Ofensiva
4 de noviembre de 2026

© 2026 — Uso restringido